

Information Security Policy - SecurePay

Version: 1.0

Effective Date: 2025-06-12

Review Date: 2026-06-12

Prepared by: Ubuntu GRC

Executive Snapshot

- **Scope:** Protects all SecurePay information assets and applies to all personnel and third parties with access.
- **Core Objective:** Ensures confidentiality, integrity, and availability (CIA) of information, with a strong focus on POPIA compliance.
- **Key Controls:** Implements ISO 27001:2022 Annex A controls across organizational, people, physical, and technological domains.
- **Regulatory Alignment:** Fully compliant with POPIA's 8 conditions for lawful processing of personal information.
- **Business Benefit:** Establishes a robust security posture, reduces risk of data breaches, and builds trust with customers and regulators.

1. Introduction

This Information Security Policy (ISP) establishes the principles, responsibilities, and requirements for managing information security within SecurePay. It is designed to protect SecurePay's information assets from all threats, whether internal or external, deliberate or accidental, and to ensure business continuity, minimize business damage, and maximize return on investments and business opportunities. This policy aligns with the requirements of ISO 27001:2022 and the Protection of Personal Information Act (POPIA) of South Africa.

2. Scope

This policy applies to all SecurePay employees, contractors, temporary staff, and third parties who have access to SecurePay's information assets, systems, and networks. It covers all information assets, regardless of their form (e.g., electronic, paper, verbal) or location.

3. Information Security Objectives

SecurePay is committed to:

- * Ensuring the confidentiality, integrity, and availability (CIA) of all information assets.
- * Complying with all applicable legal, regulatory, and contractual requirements related to information security and data privacy, including POPIA.
- * Protecting personal information of data subjects as required by POPIA.
- * Managing information security risks effectively through a structured risk management process.
- * Promoting a culture of information security awareness and responsibility among all personnel.
- * Continuously improving the Information Security Management System (ISMS).

4. Roles and Responsibilities

- Board of Directors/Senior Management: Responsible for approving the ISP, providing resources for information security, and ensuring that information security objectives are met.
- Information Security Officer (ISO): Responsible for developing, implementing, maintaining, and reviewing the ISMS. This role will also serve as the Information Officer as per POPIA requirements.
- All Employees and Contractors: Responsible for adhering to this policy and related information security procedures, and for reporting any suspected information security incidents.
- Asset Owners: Responsible for identifying and classifying information assets, and for ensuring appropriate security controls are applied.

5. Information Security Controls (Aligned with ISO 27001:2022 Annex A)

SecurePay implements a range of information security controls categorized as follows:

5.1. Organisational Controls

- Information Security Policies: A set of policies, including this ISP, will be established, reviewed, and communicated to all relevant parties.
- Information Security Roles and Responsibilities: Clear roles and responsibilities for information security will be defined and assigned.

- **Contact with Authorities:** SecurePay will maintain appropriate contacts with relevant authorities (e.g., regulatory bodies, law enforcement) regarding information security matters.
- **Threat Intelligence:** Information about information security threats will be collected and analyzed to inform risk assessments and control implementation.
 - **Information Security in Supplier Relationships:** Security requirements will be established and enforced for all third-party suppliers and partners.
- **Information Security Incident Management:** A process for managing information security incidents, including reporting, assessment, response, and learning, will be established.
- **Compliance with Legal and Contractual Requirements:** All legal, statutory, regulatory, and contractual obligations related to information security will be identified and complied with.

5.2. People Controls

- **Screening:** Background checks will be conducted for all new employees and contractors with access to sensitive information.
- **Information Security Awareness, Education, and Training:** All employees and contractors will receive regular information security awareness training, including specific training on POPIA requirements and data protection best practices.
- **Disciplinary Process:** A formal disciplinary process will be in place for violations of information security policies.
- **Remote Working:** Specific controls will be implemented to ensure the security of information when working remotely.

5.3. Physical Controls

- **Physical Security Perimeters:** Secure areas will be defined and protected by appropriate physical security controls (e.g., access control systems, surveillance).
- **Physical Entry Controls:** Access to secure areas will be restricted to authorized personnel only.
- **Protection Against Physical and Environmental Threats:** Measures will be in place to protect information assets from physical and environmental hazards (e.g., fire, flood, power outages).
- **Clear Desk and Clear Screen Policy:** A clear desk and clear screen policy will be enforced to reduce the risk of unauthorized access to information.

5.4. Technological Controls

- **Endpoint Security:** All endpoints (e.g., laptops, mobile devices) will be protected with appropriate security software (e.g., anti-malware, firewalls).
- **Secure Authentication:** Strong authentication mechanisms, including multi-factor authentication (MFA) where appropriate, will be implemented for access to systems and applications.
- **Access Rights Management:** Access rights to information and systems will be granted based on the principle of least privilege and reviewed regularly.
- **Network Security:** Network security controls, including segregation and intrusion detection/prevention systems, will be implemented.
- **Data Encryption:** Sensitive data will be encrypted both at rest and in transit.
- **Backup and Restoration:** Regular backups of critical information will be performed and tested to ensure recoverability.
- **Logging and Monitoring:** System and application logs will be collected, monitored, and reviewed for security events.
- **Secure Development Lifecycle:** Security will be integrated into the software development lifecycle for all in-house developed applications.

6. POPIA Alignment

SecurePay is committed to complying with the eight conditions for lawful processing of personal information as stipulated by POPIA:

- **Accountability:** The Information Officer is responsible for ensuring compliance with POPIA.
- **Processing Limitation:** Personal information will be processed lawfully, minimally, and with consent where required.
- **Purpose Specification:** Personal information will be collected for specific, explicit, and legitimate purposes.
- **Further Processing Limitation:** Further processing will be compatible with the original purpose of collection.
- **Information Quality:** Personal information will be accurate, complete, and up-to-date.
- **Openness:** Data subjects will be informed about the processing of their personal information.
- **Security Safeguards:** Appropriate technical and organizational measures will be implemented to protect personal information.
- **Data Subject Participation:** Data subjects' rights, including access, correction, and deletion of their personal information, will be facilitated.

7. Policy Review

This policy will be reviewed at least annually, or more frequently if there are significant changes to SecurePay's business operations, technology, or the legal and regulatory landscape. Any amendments to this policy must be approved by senior management.

8. Enforcement

Any violation of this policy may result in disciplinary action, up to and including termination of employment or contract, and may also lead to legal action.